

Phases of Ethical Hacking

Reconnaissance (Recon)

- Passive or active information gathering to learn about the target (assets, domains, people, technologies).
- Build an initial picture of the target so you know where to look next.
- Before a physical audit, a security team checks the company website, job postings, and LinkedIn to find subdomains, employee emails, and tech stack.

Scanning (Discovery)

- Active probing to discover live hosts, open ports, running services, and vulnerabilities.
- Identify reachable systems and weak points that could be tested further.
- Port scans, service/version detection, and vulnerability scans (in a lab or with permission).
- A blue-team runs a network scan on their own servers to find an old FTP service left open so they can close it.

Exploitation (Gaining Access)

- Attempting to safely verify a vulnerability by exploiting it (with authorization) to demonstrate impact.
- Prove that a vulnerability can be abused and measure the potential damage.
- In a sanctioned penetration test, the tester demonstrates that an unpatched web app can be used to access customer records, then stops and documents the finding.

Reporting (Delivering Findings)

- Documenting discoveries, impact, reproduction steps, and remediation advice in a clear report.
- Give stakeholders actionable guidance to fix issues and reduce risk.
- After a pentest, the consultant gives the CTO a prioritized report showing critical vulnerabilities, how they were confirmed, and exact steps to patch them.